

Übungsblatt 9

Vorlesung “Cybersicherheit”

Sommersemester 2025

Praktische Übung DoS, DNS, Cross-Site Scripting, SQL-Injection

XSS und SQL-Injection

XSS (Cross-Site Scripting) bezeichnet das Einschleusen von HTML-Code auf fremden Internetseiten. Dieser eingeschleuste Code wird dazu verwendet einen Angriff auf den Besucher der Webseite (Client) zu starten. Bei der SQL Injection wird mangelnde ‘*Sanitization*’ ausgenutzt. Die für SQL-Injection notwendigen Schwachstellen entstehen wenn vom Nutzer kontrollierte Variablen ohne weitere Kontrollen (*checks*) verarbeitet werden.

Aufgabe 1.

- Beschreiben Sie die drei Typen von XSS Angriffen: *Reflected XSS*, *Stored XSS* und *DOM-Based XSS*.
- Um XSS zu vermeiden empfiehlt es sich jegliche Benutzereingaben zu filtern (‘*Sanitization*’). Eine weitere Maßnahme zur Vermeidung von XSS ist *CSP* (*Content Security Policy*). Beschreiben Sie die Funktion sowie die Vor- und Nachteile von CSP.
- Beschreiben Sie wie SQL-Injection funktioniert und wie Sie eine Anfrage formulieren würden, um die Loginmaske einer Webseite zu umgehen und auf den Account **administrator** zuzugreifen, von der Sie wissen, dass die Passwörter mit SQL-Query in Listing 1 überprüft werden. Sie können dabei die Parameter `$username` und `$password` über das Formular frei eingeben.
- Beschreiben Sie sowohl abstrakt als auch konkret, wie Sie den Query aus der vorhergehenden Teilaufgabe (Listing 1) verändern müssen, um SQL-Injection zu verhindern. Sie können sich bei der konkreten Beschreibung eine gängige Programmiersprache für das Web (z.B. PHP) aussuchen.

```
1 SELECT uid FROM users WHERE username = " + $username + "  
2 AND password = " + $password + "
```

Listing 1: SQL Injection Query

Vielen Dank an Prof. Dr. Helmut Reiser von der Ludwig-Maximilians-Universität München für diese Aufgaben.

Denial-of-Service

Aufgabe 2.

In der Vorlesung haben Sie Denial-of-Service (DoS) und Distributed Denial-of-Service (DDoS) Angriffe kennen gelernt. Beantworten Sie die folgenden Fragen.

- a) Was ist das (technische) Ziel eines DoS-Angriffs?
- b) Benennen Sie die drei sogenannten CIA-Ziele. Welche dieser Ziele werden bei einem Denial-of-Service Angriff verletzt? Begründen Sie!
- c) Benennen und beschreiben Sie unterschiedliche Angriffstechniken für die Durchführung von DDoS-Angriffen.
- d) Worin unterscheiden sich DoS und DDoS Angriffe? Warum sind letztere schwieriger abzuwehren?
- e) Was ist das Konzept hinter sogenannten ‘Amplification’-Angriffen? Nennen Sie Beispiele für Amplification-Angriffe!

Botnetze

Aufgabe 3.

- a) Nennen Sie drei bekannte Botnetze.
- b) Beschreiben Sie zwei Methoden, wie ein neues System Teil eines Botnetzes werden kann.
- c) Was ist ein Command&Control-Server?
- d) Skizzieren Sie ein Botnetz bestehend aus
 - einem Angreifer,
 - einem Command&Control-Server,
 - drei Bots und
 - einem Opfer (Victim)

Zeichnen Sie die Kommunikationsflüsse ein, wenn der Angreifer mit Hilfe der Bots einen DDoS-Angriff auf das Opfer startet.

Abwehr von Denial-of-Service Angriffen

Aufgabe 4.

- a) Wie kann man Denial-of-Service Angriffe abwehren?
- b) Nennen und beschreiben Sie mögliche Probleme bei der Erkennung von DDoS-Angriffen auf Schicht 7 des ISO/OSI-Referenzmodells.
- c) Was ist das grundsätzliche Problem bei der Erhöhung der Kapazität von IT-Infrastruktur zur Abwehr von DoS-Angriffen?
- d) Beschreiben Sie die Unterschiede zwischen On-Site und Off-Site Robustheitsmaßnahmen.
- e) Was ist ein Content Delivery Network (CDN)? Wie kann es zur Abwehr von DDoS-Angriffen eingesetzt werden?
- f) Erklären Sie das DNS-basierte Routing innerhalb eines CDNs.

Bonusaufgaben

Aufgabe 5.

Installieren Sie XAMPP auf Ihrem System:

<https://www.apachefriends.org/de/download.html>. Eine detaillierte Anleitung zur Installation von XAMP finden Sie unter:

<https://www.ionos.de/digitalguide/server/tools/xampp-tutorial-so-erstellen-sie-ihren-lokalen-testserver/>.

Die Organisation **OWASP** stellt eine verwundbare Web Application bereit: <https://github.com/OWASP/Vulnerable-Web-Application>.

Kopieren Sie die Dateien in den Ordner *xampp/htdocs*. Damit die verwundbare Webanwendung auch tatsächlich verwundbar ist müssen noch einige Einstellungen vorgenommen werden. Folgen Sie den Installationsanweisungen in der README.md Datei des Web-App Projektes.

Nun können Sie selbst Angriffe und SQL-Injection Angriffe auf die auf Ihrem System gehostete Web-Applikation *Vulnerable Web Application* vornehmen und sich ausprobieren. **Hinweis: Installieren Sie die Web-App ausschließlich mithilfe von XAMPP oder in einer eigenen virtuellen Maschine auf ihrem eigenem System!**